

FIAP

Turma 1AIE

NABBA

AI Engineering & Multi-Agents

Governance & Responsible AI

Parte 5 ✓

 /sergiomantovani

@ /profsergio.mantovani@fiap.com.br

Quem sou eu?



Sergio Mantovani

- 48 anos, casado, pai de uma menina de 13 anos

Hobbies principais:



Resumo profissional:

- Diretor associado de AI & Data na Accenture, líder da prática de “Responsible AI” para América Latina
- +25 anos de experiência, focado em soluções de Dados e IA, e passagens por empresas multinacionais de diversos ramos, como bens de consumo, farmacêutico, telecom, seguros e financeiro, recursos naturais, tendo exercido papéis de liderança regional América Latina e Global.
- Graduado em Análise de Sistemas, e pós-graduado em Administração e em Gestão de Projetos, além de diversos cursos e certificações técnicas e de gestão, incluindo “Responsible AI” na Universidade de Stanford/USA.
- Coautor do “Guia de IA para Conselheiros de Administração” lançado em Out/2024 (Accenture, Microsoft e IBGC).
- Professor no MBA de Data Science & IA e no MBA AI Engineering & Multi-Agents da FIAP

Contatos:



/sergiomantovani



@profsergio.mantovani@fiap.com.br

Principais empresas:

accenture

Porto

BUNGE

Mondelēz
International

Roche

natura

Expertise:

- Responsible AI
- Data & AI Strategy
- Data & AI Governance
- Data Architecture
- Data Engineering
- Data Analytics
- Project Mngmt & Agile Methods

Agenda de Aulas

Turma: 1AIE

Junho 2026						
D	S	T	Q	Q	S	S
	1	2	3	4	5	6
7	8	9	10	11	12	13
14	15	16	17	18	19	20
21	22	23	24	25	26	27
28	29	30				

Julho 2026						
D	S	T	Q	Q	S	S
			1	2	3	4
5	6	7	8	9	10	11
12	13	14	15	16	17	18
19	20	21	22	23	24	25
26	27	28	29	30	31	

Agenda da disciplina

Temas das 5 aulas - Turma 1AIE

Temas que vamos cobrir

1	Governança e Gestão de Dados
2	Riscos da IA e Princípios de IA Responsável
3	Governança, Frameworks e Regulação
4	Mitigação de Riscos da IA
5	Considerações para Agentic AI e Projeto Final

O PAPEL DO AI ENGINEER

Você não é só técnico.

Você é responsável por:

Decisões automatizadas

que afetam pessoas reais

Impacto em pessoas

clientes, funcionários, sociedade

Risco organizacional

regulatório, financeiro, reputacional

Considerações Importantes

- Procure ser pontual – As aulas iniciam-se às 19h e terminam às 23h
 - Chamadas são liberadas às 19:15h e 22:40h
- Se possível, silencie seu celular e os demais canais de comunicação. Desconecte-se!
- Será ótimo se você puder ligar sua câmera!!
- Participe das aulas
 - Pergunte. Este é o momento!
 - Compartilhe exemplos da sua experiência profissional, pessoal ou de algo que você leu
 - Traga novos assuntos ligados à disciplina
 - Seu feedback é precioso
- Faça as atividades sugeridas em sala de aula
- Apesar de virtual, sua participação deve ser real

Onde estamos na disciplina

5 partes, perspectivas complementares

01

Governança & Gestão de Dados

DAMA, qualidade, ciclo de vida, metadados, produto de dados

02

Riscos da IA & Princípios de IA Responsável

Taxonomia de riscos · princípios de IA Responsável · Estudo de Casos

03

Governança, Frameworks e Regulação

Melhores Práticas em Governança de IA · NIST AI RMF · ISO 42001 · EU AI Act · LGPD · PL 2338

04

Mitigação de Riscos da IA

Justiça · robustez · XAI · privacidade · segurança · guardrails

05

Agentic AI & Projeto Final

Agentes autônomos, riscos amplificados · Quantum Commerce

VOCÊ ESTÁ AQUI



GOVERNANCE &
RESPONSIBLE AI

P A R T E 0 5

Agentic AI

Riscos & Mitigações

Considerações específicas para sistemas de IA com autonomia

AI Engineering & Multi-Agents · Turma 1AIE



01

Fundamentos

O que é um agente de IA,
componentes,
arquitetura e classificação

02

Riscos específicos

OWASP Top 10 for Agentic
Applications +
ameaças amplificadas pela
autonomia

03

Mitigações

Defesa em profundidade,
governança progressiva,
ferramentas e ciclo de vida

01

BLOCO 01

Fundamentos

O que é Agentic AI, arquitetura, componentes, classificação e diferenças vs. IA tradicional e IA generativa.



Da IA preditiva à IA agêntica

ANTES de 2017

IA Preditiva / Tradicional

*Modelos especializados
treinados para uma tarefa.*

- Dados estruturados
- Output: classificação, previsão, score
- Sem geração de conteúdo
- Sem ações no mundo
Ex.: detecção de fraude, recomendação, churn

2017+

IA Generativa

*LLMs respondem em
linguagem natural.*

- Texto, imagem, código, áudio gerados sob demanda
- Resposta em UMA chamada
- Humano dirige a interação
- Sem persistência ou ações autônomas
Ex.: ChatGPT, Copilot Chat, resumo, redação

2024+

Agentic AI

*Sistemas que decidem
e agem por conta própria.*

- Planejamento multi-step
- Memória persistente
- Uso de ferramentas / APIs
- Autonomia + colaboração entre agentes
Ex.: agente de pesquisa, SDR autônomo, code agent

Autonomia, escopo e impacto crescem → os riscos também

IA tradicional: ML, DL, CV, NLP

DEFINIÇÃO

Sistemas que aprendem padrões a partir de dados rotulados ou não, e produzem previsões, classificações ou agrupamentos para uma tarefa específica.

CARACTERÍSTICAS-CHAVE

- Modelo treinado para UMA tarefa
- Output: número, label, score
- Sem geração de conteúdo
- Sem ações no mundo
- Determinístico após treinamento

SUB-CAMPOS PRINCIPAIS

ML

Machine Learning clássico

Algoritmos como regressão, árvores de decisão, random forest, SVM, clustering.

Casos: detecção de fraude, scoring de crédito, churn, segmentação de clientes.

Ferramentas: scikit-learn · XGBoost · LightGBM

DL

Deep Learning

Redes neurais multi-camada que aprendem representações hierárquicas dos dados.

Casos: visão computacional, fala, séries temporais complexas, recomendação.

Ferramentas: TensorFlow · PyTorch · Keras

CV/NLP

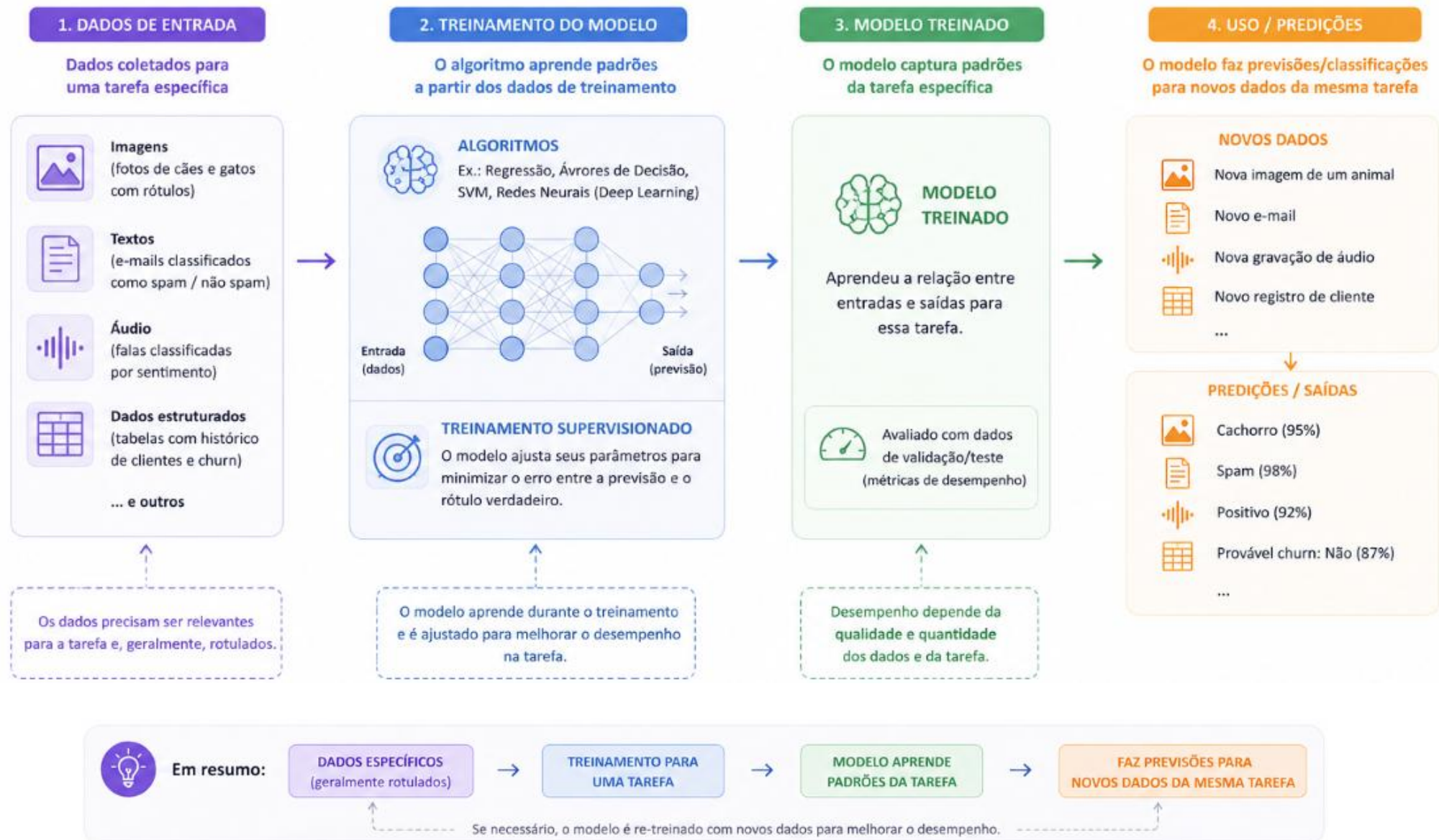
Visão e linguagem (especialistas)

Modelos especializados em imagens (CNN, ResNet) ou texto (BERT, RoBERTa).

Casos: OCR, classificação de imagens, NER, sentiment analysis, tradução.

Ferramentas: Hugging Face · Azure AI Vision · OpenCV

IA tradicional: ML, Deep Learning, Computer Vision



IA Generativa: LLMs, foundation models, prompting

DEFINIÇÃO

Modelos de fundação (foundation models) treinados em larga escala que GERAM conteúdo — texto, código, imagem, áudio — em resposta a um prompt.

O QUE MUDOU EM RELAÇÃO À IA TRADICIONAL

- UM modelo serve a MUITAS tarefas
- Aprende em pré-treino + ajuste fino
- Interface = linguagem natural
- Output = conteúdo novo, não só label
- Não-determinístico (probabilístico)

ANATOMIA DE UM SISTEMA GENERATIVO

1

Como funciona — arquitetura Transformer (2017)

Tokens entram, mecanismo de atenção pondera relações, modelo prevê o próximo token. Repete. Em escala (bilhões de parâmetros) emergem capacidades como raciocínio, tradução e geração coerente.

Modelos: GPT-4o · Claude · Gemini · Llama · Mistral · Phi

2

Modalidades — texto e além

Texto (LLM), código (Codex/Copilot), imagem (DALL-E, Stable Diffusion, Imagen), áudio (Whisper, ElevenLabs), vídeo (Sora, Veo). Multimodais combinam várias.

Padrões: chat, completion, RAG (Retrieval-Augmented Generation), fine-tuning

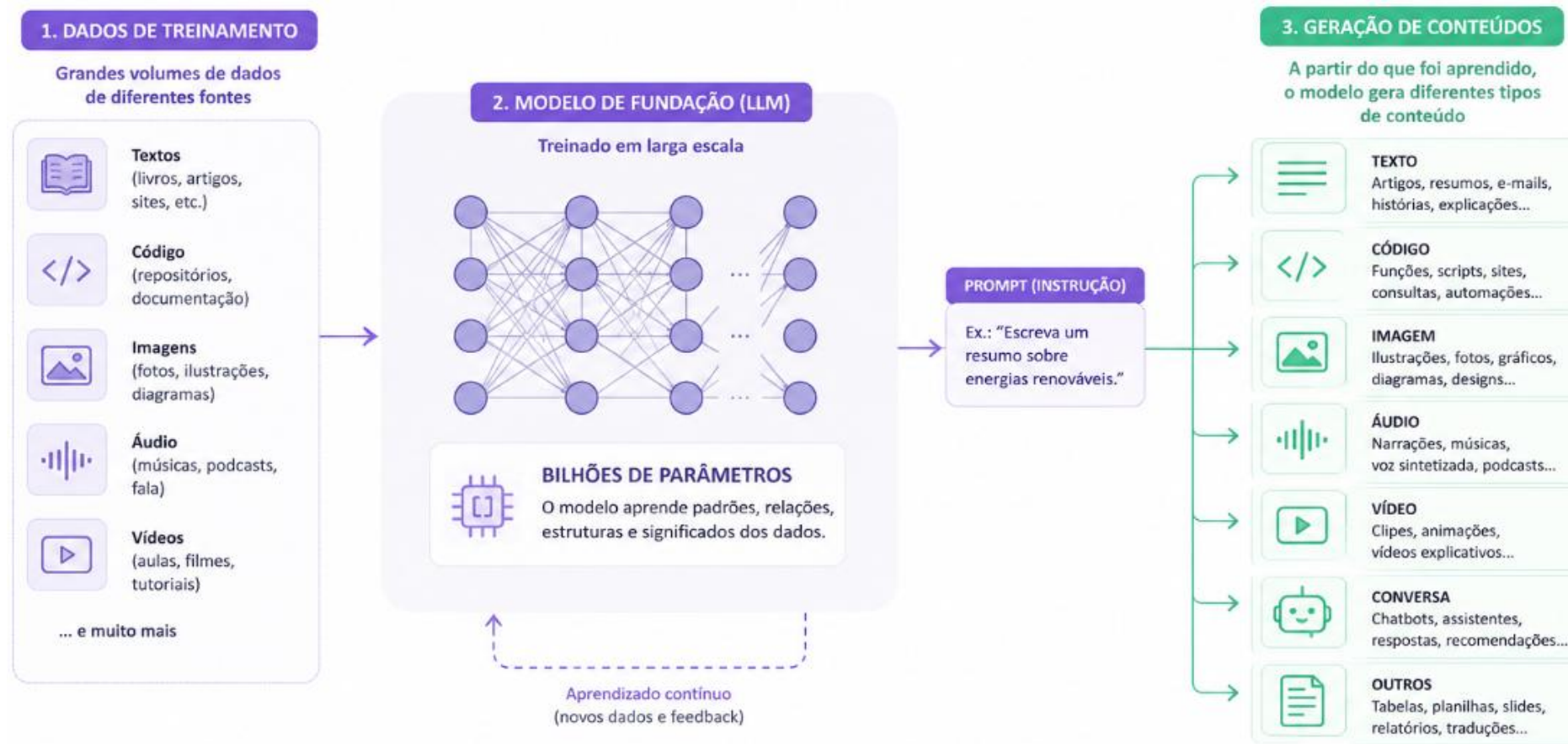
3

Casos típicos & limites

Casos: redação, resumo, atendimento conversacional, geração de código, análise de documentos. Humano dirige cada interação — o modelo responde, não decide.

Limites: alucinação, vieses do pré-treino, sem memória persistente, sem ações no mundo

IA Generativa: LLMs, foundation models, prompting



Em resumo:

DADOS DIVERSOS



TREINAMENTO EM LARGA ESCALA

(BILHÕES DE PARÂMETROS)



APRENDIZADO

(PADRÕES E SIGNIFICADOS)



GERAÇÃO DE MÚLTIPLOS CONTEÚDOS

(TEXTO, IMAGEM, ÁUDIO, CÓDIGO, VÍDEO E +)

IA Agêntica: fundamentos e componentes

DEFINIÇÃO

Um agente de IA é um sistema que percebe o ambiente, raciocina, planeja e executa ações através de ferramentas, com algum grau de autonomia, em direção a um objetivo.

O QUE MUDA EM RELAÇÃO À IA GENERATIVA

- GenAI fala, Agente AGE
- Decompõe objetivo em passos
- Mantém memória entre turnos
- Invoca ferramentas / APIs
- Decide próxima ação sozinho

5 COMPONENTES DE UM AGENTE



Percepção

Recebe inputs do ambiente: usuário, eventos, dados, outros agentes.



Raciocínio

LLM (ou outro modelo) interpreta, planeja e decide o próximo passo.



Memória

Curto prazo (contexto da sessão) e longo prazo (vetor DB, histórico).



Ferramentas

Invoca APIs, bases, código, navegador, outros agentes (via MCP).



Autonomia - capacidade que define um agente

Encadeia múltiplas ações sem aprovação humana a cada passo. É um espectro:



Arquitetura de um agente de IA

1. AMBIENTE

Fontes externas que geram informações e eventos.

2. AGENTE DE IA

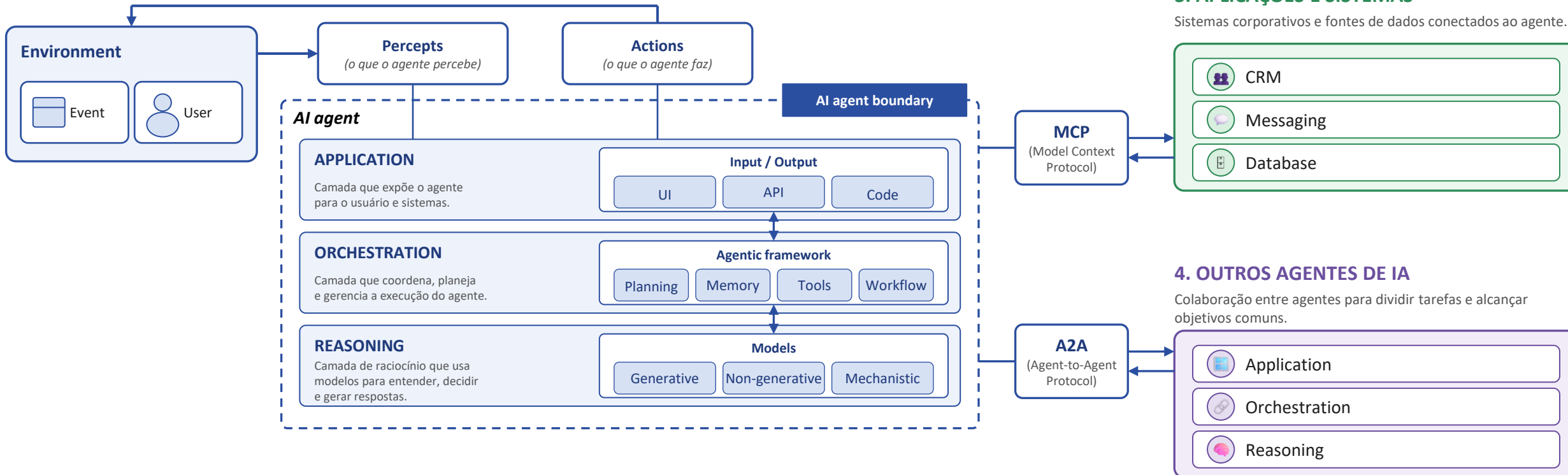
Dentro da fronteira do agente, as capacidades são organizadas em três camadas principais.

3. APLICAÇÕES E SISTEMAS

Sistemas corporativos e fontes de dados conectados ao agente.

4. OUTROS AGENTES DE IA

Colaboração entre agentes para dividir tarefas e alcançar objetivos comuns.



FLUXO DE FUNCIONAMENTO



1. PERCEBER

O agente recebe eventos e interações do ambiente.



2. RACIOCINAR

Usa modelos e memória para entender contexto e planejar.



3. AGIR

Executa ações via UI, API ou código, usando ferramentas.



4. RECEBER FEEDBACK

O ambiente reage e gera novos eventos, reiniciando o ciclo.

IA Agêntica: Sistemas Multi-Agente e Padrões

MULTI-AGENTE

Múltiplos agentes especializados colaboram para resolver um problema complexo, coordenados por um orquestrador ou via comunicação peer-to-peer.

4 PADRÕES ARQUITETURAIS COMUNS

Single agent

Um único agente com várias tools.
Mais simples, mais previsível.

Quando: caso de uso bem delimitado.

Supervisor + workers

Orquestrador delega sub-tarefas a agentes especializados.

Quando: tarefas decomponíveis em sub-problemas claros.

Hierárquico (árvore)

Sub-orquestradores comandam grupos de agentes.

Quando: problemas grandes, múltiplos domínios.

Peer-to-peer (rede)

Agentes negociam e colaboram sem hierarquia central.

Quando: ecossistema aberto, agentes de fornecedores diferentes.

COMO AGENTES SE COMUNICAM

MCP

Model Context Protocol

Agente ↔ ferramentas/recursos.
Padrão Anthropic, hoje de fato.

A2A

Agent-to-Agent

Agente ↔ outro agente.
Protocolo emergente do Google.

POR QUE MULTI-AGENTE IMPORTA PARA GOVERNANÇA

- **Maior superfície de ataque:** cada agente é mais um vetor.
- **Cascading failures:** erro de um propaga aos demais.
- **Identidade & autorização** entre agentes: quem fala com quem?
- **Observabilidade** mais difícil: tracing distribuído é obrigatório.

Classificação funcional de agentes

Antes de governar é preciso classificar. WEF propõe 5 dimensões para descrever qualquer agente.

1	2	3	4	5
Função <i>Function</i> O que o agente faz? - Assistente / copiloto - Executor autônomo - Orquestrador - Sub-agente especialista	Papel <i>Role</i> Quem ele representa? - Atendimento - Análise / pesquisa - Operacional (ações) - Compliance / auditoria	Autonomia <i>Autonomy</i> Quanto decide sozinho? - L1: Sugere - L2: Age sob aprovação - L3: Age + reporta - L4: Totalmente autônomo	Autoridade <i>Authority</i> O que ele pode fazer? - Read-only - Escrita limitada - Escrita ampla - Escrita + financeiro	Ambiente <i>Environment</i> Onde ele opera? - Sandbox isolado - Sistemas internos - Internet aberta - Sistemas críticos

+ uma 6ª dimensão transversal: PREVISIBILIDADE - o agente é determinístico ou estocástico? Quão repetível é seu comportamento?

Por que governar agentes é diferente?

Cinco propriedades dos agentes que quebram suposições da governança tradicional de IA

1

Ações no mundo real

O agente não responde, ele AGE. Move dinheiro, escreve em sistemas, manda e-mails. Erro deixa de ser "resposta ruim" e vira "ação errada com consequência".

2

Não-determinismo composto

Cada passo tem ~5-15% de erro. Em 10 passos encadeados: $0.95^{10} \approx 60\%$ de chance de chegar ao fim sem nenhum erro. Falhas se compõem.

3

Identidade não-humana (NHI)

Agentes precisam autenticar em sistemas. Surge um novo tipo de "usuário", não-humano, persistente, com permissões delegadas. RBAC tradicional não basta.

4

Memória persistente

O que entra na memória influencia decisões futuras silenciosamente. Memória pode ser envenenada, vazada ou usada para reconstrução de PII.

5

Comunicação entre agentes

Um agente fala com outro agente que fala com outro... Confiança transitiva. Um agente comprometido propaga dano em cascata pelo ecossistema.

CONSEQUÊNCIA

A governança de IA tradicional (foco em modelo, dataset, output) é necessária mas insuficiente. Precisamos governar a AÇÃO, não apenas a inferência.

02

BLOCO 02

Riscos da Agentic AI

OWASP Agentic Top 10 + ameaças amplificadas pela autonomia. Onde os agentes falham e o que está em jogo.



Riscos amplificados vs. riscos novos

Agentic AI herda os riscos da IA generativa e introduz uma nova classe de riscos próprios da autonomia

AMPLIFICADOS

Riscos que já existiam, mas que ganham nova dimensão

(herdados de IA generativa)

- **Alucinação**
Vira AÇÃO ERRADA quando o agente decide invocar uma tool com base em info inventada.
- **Viés**
Replicado em escala: agente atua sobre milhares de casos sem revisão humana.
- **Privacidade / PII**
Vazamentos não acontecem só na resposta: acontecem nas chamadas a APIs externas.
- **Prompt injection**
Não é só "output ruim": vira invocação de ações reais.
- **Toxicidade / output ofensivo**
Output do agente pode chegar a sistemas de produção, não só ao usuário.

NOVOS / ESPECÍFICOS

Riscos que só existem com autonomia

(introduzidos pela camada agêntica)

- **Goal hijack**
Atacante redireciona o objetivo do agente (ASI01 OWASP).
- **Tool misuse / RCE**
Agente é induzido a invocar tools de forma destrutiva (ASI02, ASI05).
- **Memory poisoning**
Memória de longo prazo é envenenada e influencia decisões futuras (ASI06).
- **Cascading failures**
Erro em um agente se propaga em cascata por todo o sistema (ASI08).
- **Rogue agents**
Agente desalinha sem controle do atacante, autonomia descontrolada (ASI10).
- **Identidade NHI abusada**
Agente herda permissões e age como usuário privilegiado (ASI03).

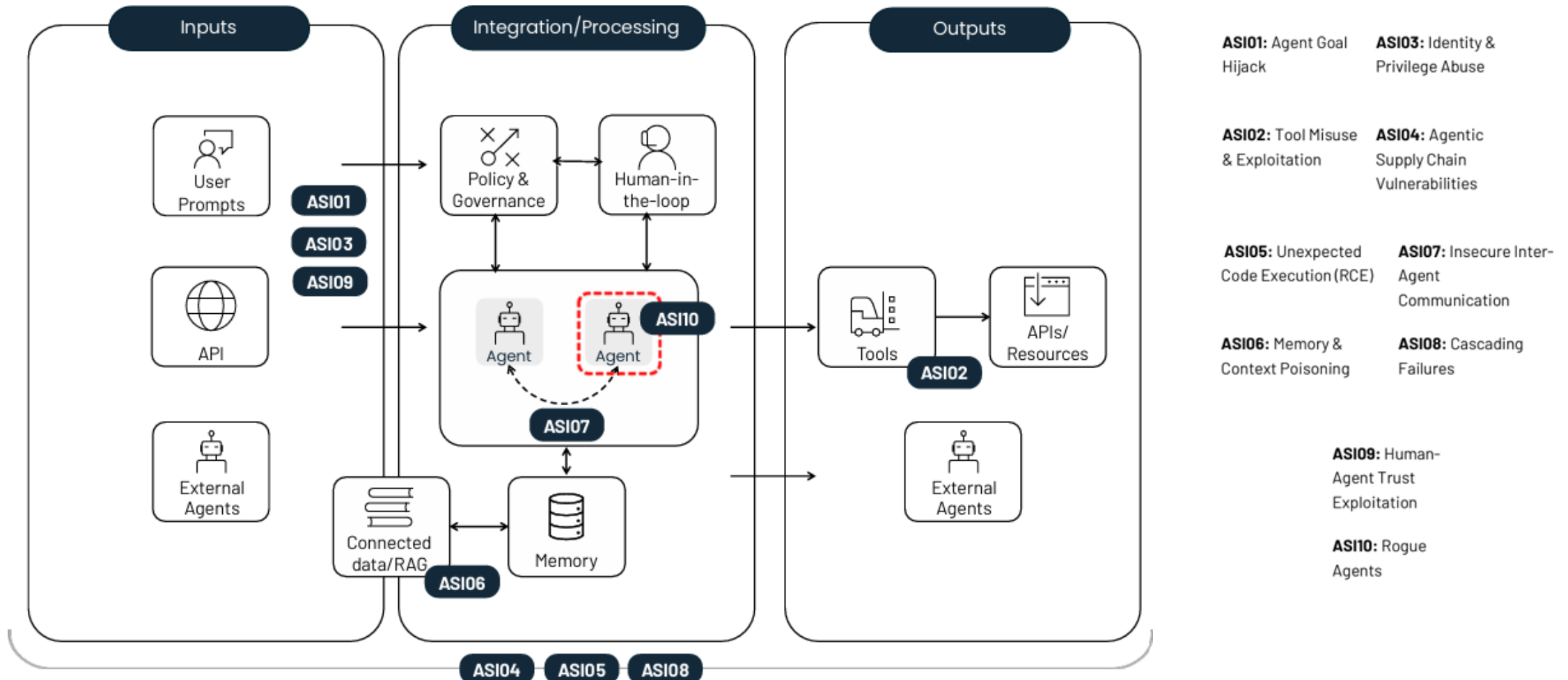
OWASP Top 10 for Agentic Applications

Uma das principais referências para quem desenvolve, defende ou audita aplicações com agentes

ASI01 Agent Goal Hijack Manipulação do objetivo via prompt injection ou dados envenenados	ASI02 Tool Misuse & Exploitation Agente induzido a usar ferramentas de forma destrutiva ou não-autorizada	ASI03 Identity & Privilege Abuse Permissões delegadas usadas além do escopo original	ASI04 Agentic Supply Chain Risco em modelos, MCP servers, plugins, frameworks e dados externos	ASI05 Unexpected Code Execution (RCE) Agente executa código não previsto via tool de execução / sandbox fraco
ASI06 Memory & Context Poisoning Memória de curto/longo prazo é corrompida com dados maliciosos	ASI07 Insecure Inter-Agent Communication Confiança transitiva entre agentes sem autenticação ou validação	ASI08 Cascading Failures Erro em um agente se propaga em cascata pelo sistema	ASI09 Human-Agent Trust Exploitation Atacante manipula humanos via UX do agente (deepfake, social engineering)	ASI10 Rogue Agents Agente passa a operar fora do escopo sem controle ativo de atacante

Onde cada risco se materializa

Cada risco tem uma localização típica no pipeline do agente. Entender isso ajuda a posicionar controles



Riscos de comportamento / objetivo

ASI01

Agent Goal Hijack

Atacante manipula o objetivo do agente via prompt injection (direta ou indireta), dados envenenados ou mensagens forjadas entre agentes.

Caso real: EchoLeak (M365 Copilot, 2025): e-mail recebido contendo instruções escondidas faz o Copilot exfiltrar dados confidenciais via call hook do navegador, sem nenhuma ação do usuário (zero-click).

MITIGAÇÕES PRINCIPAIS

- Validar intenção do usuário E intenção do agente antes de cada ação de alto impacto
- Tratar TODO input em linguagem natural como não-confiável (incluindo documentos, e-mails, resultados de busca)
- Lock do system prompt + change management formal
- "Intent capsule" - assinatura criptográfica do objetivo declarado

ASI06

Memory & Context Poisoning

A memória de curto ou longo prazo do agente é corrompida com conteúdo malicioso que vai influenciar decisões futuras silenciosamente.

Cenário: documento envenenado é indexado no RAG corporativo. Toda consulta que recupera o trecho infectado passa a sofrer manipulação — efeito persistente até o doc ser removido/reindexado.

MITIGAÇÕES PRINCIPAIS

- Sanitizar conteúdo antes de gravar em vetor DB / memória
- Versionar memória, com rollback rápido em caso de detecção
- Isolamento por tenant/usuário (não compartilhar memória entre contextos sensíveis)
- Detecção contínua de anomalia em padrões de recuperação

ASI10

Rogue Agents

Agente passa a operar fora do escopo declarado. Pode ser intencional (atacante) ou emergente (deriva, alinhamento mau).

Risco mais sutil: agente que progressivamente "otimiza" para uma métrica e acaba burlando regras secundárias. Difícil de detectar sem baseline comportamental.

MITIGAÇÕES PRINCIPAIS

- Baseline comportamental + monitoramento de desvio (behavioral drift detection)
- Kill-switch / circuit breaker centralizado
- Logs imutáveis com correlação por correlation-id
- Avaliação contínua contra cenários de jailbreak conhecidos

Riscos de execução / ferramentas

ASI02

Tool Misuse & Exploitation

Agente é induzido a invocar ferramentas legítimas de forma destrutiva, exfiltrante, ou fora do escopo permitido.

EXEMPLO

Cenários comuns:

- Agente de e-mail enviando para destinatários externos
- Agente de banco transferindo valores além do limite
- Agente de query SQL fazendo DROP TABLE

MITIGAÇÕES

- **Princípio do menor privilégio** Cada tool com escopo MÍNIMO. Read-only por padrão.
- **Validação de schema** Parâmetros validados ANTES da invocação.
- **Allowlist de tools** Por agente, por contexto, por usuário.
- **HITL para alto impacto** Confirmação humana em ações irreversíveis.
- **Rate limiting** Por tool, por agente, por janela de tempo.
- **Logging detalhado** Quem, quando, com quais parâmetros, qual resultado.

ASI05

Unexpected Code Execution (RCE)

Agente executa código não previsto via tools de execução de código (Python, shell), levando a RCE no host ou em sistemas conectados.

EXEMPLO

Vetor crítico em agentes que têm "code interpreter". Exploits típicos:

- Escape de sandbox
- Pacotes maliciosos via pip
- Comandos shell injetados em prompts

MITIGAÇÕES

- **Sandbox forte** Container isolado, sem rede salvo allowlist.
- **Read-only filesystem** Escrita só em /tmp efêmero.
- **Limites de recurso** CPU, RAM, tempo de execução.
- **Allowlist de pacotes** Não permitir pip install arbitrário.
- **Network egress filtering** Deny por padrão, allowlist explícito.
- **Deteção de payload** Análise estática do código antes de rodar.

Riscos de identidade e cadeia de suprimentos

ASI03

Identity & Privilege Abuse

Agente herda credenciais/permisões e age "em nome de" um usuário com escopo maior do que o necessário.

EXEMPLO

Caso típico: agente de produtividade autenticado via OAuth do usuário corporativo. Ele herda TODAS as permissões: leitura de e-mails, drives, calendários, mesmo precisando só de uma fração.

MITIGAÇÕES

- **NHI - Non-Human Identity** Identidade própria por agente, não "impersonação" do usuário.
- **OAuth scope mínimo** Solicitar apenas escopos estritamente necessários.
- **Rotação de credenciais** Tokens de curta duração + refresh controlado.
- **Audit logging** Quem invocou o agente, em nome de quem, autorizando o quê.
- **Just-in-time access** Privilégios temporários, expiram após a tarefa.

ASI04

Agentic Supply Chain Vulnerabilities

Risco em qualquer componente da cadeia: modelo (Hugging Face), framework (LangChain, AutoGen), MCP server, plugin, dataset de treino, prompt template público.

EXEMPLO

Casos públicos: pacotes maliciosos no PyPI imitando libs de IA, MCP servers comunitários com backdoor, model cards com prompts injetados, datasets com triggers escondidos.

MITIGAÇÕES

- **SBOM para IA** Bill of materials de modelos, datasets, prompts, MCPs.
- **Verificação de origem** Modelos só de fontes verificadas — Hugging Face confiáveis, mirrors internos.
- **Model signing** Sigstore, ML-BOM, Cloud-native attestation.
- **MCP server registry** Allowlist de MCPs aprovados pelo time de segurança.
- **Scanning contínuo** Verificar vulnerabilidades em pacotes e modelos.

Riscos de comunicação e sistema

ASI07

Insecure Inter-Agent Communication

Confiança transitiva entre agentes sem autenticação ou validação. Mensagens A2A podem ser forjadas, replayed ou interceptadas.

EXEMPLO

Cenário: agente "orquestrador" delega tarefa a sub-agente. Atacante intercepta a mensagem (man-in-the-middle no MCP) ou se passa pelo sub-agente, retornando dados manipulados.

MITIGAÇÕES

- **Autenticação mútua** mTLS ou tokens curtos entre agentes.
- **Assinatura de mensagens** Cada mensagem A2A assinada e verificada.
- **Validação de schema** Não aceitar mensagens fora do contrato esperado.
- **Zero trust entre agentes** Cada agente é hostil até prova em contrário.
- **Logging de fluxo** Trace distribuído (OpenTelemetry) cobrindo o multi-agente.

ASI08

Cascading Failures

Erro em um agente se propaga em cascata por todo o sistema. Pode ser técnico (timeout) ou lógico (decisão errada que vira input de outro).

EXEMPLO

Caso clássico em multi-agente: agente A alucina um valor → agente B baseia plano nesse valor → agente C executa o plano. Erro composto, sem checkpoint.

MITIGAÇÕES

- **Circuit breakers** Por agente, por tool, por correlation-id.
- **Timeout agressivo** Loops infinitos morrem rápido.
- **Validação intermediária** Outputs validados antes de virar input do próximo.
- **Rollback / compensação** Saga pattern para ações distribuídas.
- **Limite de iterações** Número máximo de passos por sessão.

Riscos de interação humana

ASI09

Human-Agent Trust Exploitation

Atacante explora a **CONFIANÇA** do humano no agente — não ataca o agente, ataca o usuário **VIA** o agente.

Personificação



Agente legítimo é manipulado para reforçar comandos suspeitos como se viessem dele. Usuário confia e clica.

Deepfake interno



Voz/vídeo gerados pelo agente para se passar por um humano da organização (CEO, CFO). Fraude do CEO 2.0.

Confiança erodida pelo viés de automação



Usuário aceita decisões do agente sem questionar: humano-in-the-loop vira humano-rubber-stamp.

MITIGAÇÕES

Tornar a confiança auditável, não suposta

- **Indicação clara de IA**

Sempre identificar conteúdo gerado por IA (selo, watermark, marca de áudio).

- **Cadeia de procedência**

Cada output traz origem rastreável (C2PA, Content Credentials).

- **Confirmação fora-de-banda**

Para ações sensíveis: confirmação via outro canal (SMS, app authenticator).

- **Educação do usuário**

Usuários treinados a reconhecer sinais de deepfake e personificação.

- **Friction adequado**

HITL real, não apenas tela de "OK". Forçar leitura.

- **Deteção de anomalia comportamental**

Ações fora do padrão do usuário disparam revisão.

03

BLOCO 03

Mitigando os riscos

Defesa em profundidade, governança progressiva,
ciclo de vida e ferramentas: o que fazer
de fato no dia a dia.



Defesa em profundidade para agentes

Nenhum controle isolado resolve. Cada camada cobre um conjunto de riscos: falha em uma é compensada pela próxima.

1	Governança & política <i>Quem decide, quem aprova, quem responde</i>	Comitê de IA, RACI, classificação de risco, políticas de uso
2	Identidade & permissões <i>Quem o agente é + o que pode fazer</i>	NHI, OAuth scope mínimo, JIT access, rotação
3	Input & guardrails <i>Filtra e sanitiza o que entra</i>	Validação de prompt, classificadores de injection, content safety
4	Modelo & raciocínio <i>Qualidade e robustez do core</i>	Eval contínuo, red teaming, model cards, system prompt versionado
5	Tools & ações <i>Limita o que o agente consegue fazer</i>	Allowlist, schema, HITL, rate limit, sandbox forte, dry-run
6	Observabilidade & resposta <i>Detectar, alertar, conter, reverter</i>	Logs estruturados, distributed tracing, anomalia, kill switch

Cada risco da OWASP Top 10 é mitigado por DUAS OU TRÊS camadas, não apenas uma!

Práticas progressivas de governança

Recomendação WEF: governança proporcional ao escopo e autonomia. Comece pelo essencial, evolua progressivamente.



Princípio de governança proporcional. Agente de baixo risco tem menos controles; agente crítico tem TODOS

Mitigação ao longo do ciclo de vida

Cada fase tem oportunidades específicas, quanto mais à esquerda (design) o controle entra, mais barato sai

01 · DESIGN

Antes de codificar

● Threat modeling

STRIDE p/ agentes, mapping OWASP ASI

● Risk classification

Use case scorecard (autonomia × autoridade)

● Choose architecture

Single vs multi-agent, autonomia mín. necessária

● Privacy-by-design

Minimizar dados, segregar tenants

● Define HITL gates

Quais ações exigem aprovação humana

02 · BUILD

Durante o desenvolvimento

● Validate tools schema

Pydantic, JSON schema, OpenAPI

● System prompt control

Versionado, code review, locked

● Eval harness

Test suite com casos de jailbreak

● SBOM AI

Modelos, libs, MCPs, datasets

● Secret scanning

Tokens, chaves, no prompt e no log

03 · DEPLOY

Indo para produção

● Canary rollout

Pequeno % usuários, ramp gradual

● Sandbox isolation

Filesystem, rede, recursos limitados

● Identity / NHI

Entra Agent ID, IAM dedicado

● Guardrails ativos

Content safety, injection detection

● Kill switch testado

Verificar funcionamento real

04 · OPERATE

Em produção

● Eval contínuo

Bateria periódica + amostragem em prod

● Observability

Logs, traces, métricas, alertas

● Drift detection

Comportamental e de performance

● Incident response

Playbook específico para agentes

● Periodic re-cert

Revisão de baseline a cada N meses

Human-in-the-loop: 4 padrões de design

Não existe "HITL" único. Quatro padrões cobrem desde supervisão total até intervenção excepcional

HUMAN-IN

Humano APROVA cada ação relevante

Maior segurança, menor velocidade

QUANDO USAR

- Ações irreversíveis
- Alto valor financeiro
- Decisões sobre pessoas
- Compliance crítico

EXEMPLO

Ex.: aprovação de transferência, demissão, decisão de crédito

HUMAN-ON

Humano OBSERVA e pode intervir

Equilíbrio entre velocidade e controle

QUANDO USAR

- Operações com SLA apertado
- Volume médio-alto
- Reversíveis em curto prazo
- Métricas claras de qualidade

EXEMPLO

Ex.: triagem de tickets, resposta automática, monitoring

HUMAN-OUT

Humano AUDITA depois (post-hoc)

Velocidade total, com revisão por amostragem

QUANDO USAR

- Decisões reversíveis
- Baixo impacto unitário
- Volume muito alto
- Caso de uso bem testado

EXEMPLO

Ex.: classificação de e-mail, roteamento, sumarização

HUMAN-EX

Humano só em EXCEÇÕES

Modelo decide quando precisa de humano

QUANDO USAR

- Confiança baixa do modelo
- Caso fora do baseline
- Anomalia detectada
- Solicitação explícita

EXEMPLO

Ex.: agente que escala automaticamente para humano

Avaliação contínua de agentes

Agentes precisam de mais que LLM eval. A autonomia muda o que se mede e como se mede

L1

Modelo (LLM eval)

Capacidades base do modelo subjacente

MÉTRICAS-CHAVE

- Benchmarks (MMLU, HumanEval, GPQA)
- Robustez a prompts adversariais
- Vieses, fairness, toxicidade
- Hallucination rate

Ferramentas: HELM, lm-eval-harness, DeepEval, Promptfoo

L2

Componentes (RAG, tools)

Qualidade dos building blocks

MÉTRICAS-CHAVE

- Retrieval: precision/recall@k, MRR
- Tool selection accuracy
- Tool argument correctness
- Citation faithfulness

Ferramentas: Ragas, TruLens, LlamaIndex evals, Phoenix

L3

Tarefa (single-step)

O agente cumpriu O OBJETIVO?

MÉTRICAS-CHAVE

- Task success rate
- Tool call success
- Edge case robustness
- Latência fim-a-fim

Ferramentas: AutoGen Eval, LangSmith, Galileo Agent Evals

L4

Trajetória (multi-step)

O CAMINHO até o resultado também importa

MÉTRICAS-CHAVE

- Trajectory similarity vs. gold
- Number of steps (eficiência)
- Custo por tarefa (tokens, \$)
- Recovery from errors

Ferramentas: Arize Phoenix Agent Eval, Weights & Biases Weave

Observabilidade e detecção em runtime

Em agentes, o tradicional "3 pilares" da observabilidade ganha um quarto pilar: comportamento

LOGS

Estruturados

Cada decisão, cada tool call, cada output recuperável e rastreável.

- correlation-id atravessa todo o fluxo
- PII redacted antes da gravação
- Retenção alinhada com LGPD/GDPR
- Imutabilidade para auditoria

TRACES

Distributed

Visão fim-a-fim de uma sessão de agente — incluindo sub-agentes.

- OpenTelemetry como padrão
- Spans por step, tool, sub-agent
- Latência por componente
- Visibilidade de cascade failures

METRICS

Tempo real

Indicadores agregados que disparam alertas quando algo desvia.

- Tool calls/min, custo/sessão
- Taxa de erro por tool
- Distribution shift no input
- p50/p95/p99 latency

BEHAVIOR

Baseline

O "4º pilar" específico de agentes: PADRÃO comportamental.

- Sequência típica de tools
- Comprimento típico de trajetória
- Distribuição de outcomes
- Detecção de "agente errante"

PRINCIPAIS FERRAMENTAS

Open source
AI-native APM
Cloud-native

OpenTelemetry · Phoenix · OpenLLMetry · Langfuse
Datadog · Arize · Galileo · LangSmith · Weights & Biases Weave
Azure Monitor + AI Foundry tracing · AWS Bedrock Guardrails Logs

Ferramentas para governar agentes: visão comparativa

Mapa das principais ferramentas por categoria. Não é exaustivo, foca no que está sendo adotado em produção.

Categoria	Ferramentas	O que faz	Pontos fortes	Pontos de atenção
Avaliação de agentes	Azure AI Foundry Evals, LangSmith, Braintrust, DeepEval, Ragas, OpenAI Evals	Mede qualidade, toxicidade, groundedness, tool-call success	Integração com pipelines de CI/CD; suporte a LLM-as-judge	LLM-as-judge tem viés; cuidado com data leakage em datasets de eval
Observabilidade & tracing	Langfuse, Arize Phoenix, Datadog LLM Obs, Weights & Biases, Helicone	Tracing distribuído de tools/sub-agents, logs estruturados	Visão de runtime em produção; alertas de drift	Custo cresce com volume; PII aparece em traces — tratar dados sensíveis
Guardrails & safety	Azure Content Safety, NeMo Guardrails, Guardrails AI, Llama Guard	Filtros de input/output, topic/PII control, detecção de injection	Bloqueio em tempo real; regras declarativas	Falsos positivos afetam UX; não substitui defesa em profundidade
Identidade não-humana (NHI)	Microsoft Entra Agent ID, Okta Identity for Agents, AWS IAM Identity Center	Identidade própria por agente, lifecycle, least privilege	Auditoria por agente, revogação granular, compliance	Mercado novo; integrações ainda limitadas; chave de sessão pode vazar
Security & AI posture	MS Defender for Cloud (AI), Palo Alto AI Runtime Security, Lakera, ProtectAI	Detecção de prompt injection, model risk, shadow AI, postura	Cobertura cross-cloud; integra com SIEM/SOAR	Telemetria precisa estar plugada nos agentes; cuidado com vendor lock-in
Frameworks de agente	LangGraph, AutoGen, Semantic Kernel, CrewAI, LlamaIndex Agents	Orquestração, planning, memória, sub-agents, tool use	Velocidade de prototipagem; comunidade ativa; padrões emergentes	API instável; lock-in com framework; debugging difícil em produção

Fontes: Compilação a partir de: documentação oficial dos fornecedores · OWASP Agentic AI Threats & Mitigations · Palo Alto — A Complete Guide to Agentic AI Governance · Datadog AI Observability

04

BLOCO 04

Appendix: stack Microsoft / Azure

Como as ferramentas Microsoft endereçam cada categoria de risco: das 3 zonas de governança ao Foundry, Copilot Studio, Defender, Purview e Entra Agent ID.

Modelo das 3 zonas de governança

A Microsoft estrutura governança de agentes em três zonas, baseadas em risco × complexidade técnica.

ZONA 1

Personal Productivity

Agentes de produtividade pessoal configurados pelo próprio usuário (ex.: agentes em Copilot Chat).

- Baixa criticidade
- Configuração self-service
- Governança leve
- Logs básicos via M365

Risco × complexidade BAIXOS

ZONA 2

Team Collaboration

Agentes compartilhados em equipes (ex.: agentes publicados no Copilot Studio para uma área de negócio).

- Risco moderado
- Aprovação por TI/área
- DLP, Purview, sensitivity labels
- Logging centralizado

Risco × complexidade MÉDIOS

ZONA 3

Enterprise Managed

Agentes de missão crítica construídos pela engenharia (ex.: agentes em Azure AI Foundry).

- Alta criticidade
- SDLC + threat modeling
- Defender, Sentinel, Entra Agent ID
- Observabilidade completa

Risco × complexidade ALTOS

→ governança progressiva: cada zona herda os controles da anterior ←

Onde construir? Foundry, Copilot Studio ou M365 Copilot

M365 COPILOT

Agentes empacotados

*Copilot Chat + agentes pré-construídos
(Sales, Service, Finance, Studio).*

Pro código

FORTES

- Time-to-value máximo
- Integrado ao M365
- Grounded em Graph
- Governance pelo tenant

ATENÇÃO

- Customização limitada
- Lock-in alto
- Pricing por usuário

COPILOT STUDIO

Low-code multi-canal

*Plataforma low-code para construir
agentes; deploy em Teams, Web, Voz.*

Citizen + pro

FORTES

- Connectors prontos
- Topics e plugins customizáveis
- Integra Power Platform
- Governance via Studio Admin

ATENÇÃO

- Ainda assim, lock-in M365
- Debugging menos rico que código
- Limites em multi-agent

AZURE AI FOUNDRY

Pro-code completo

*Plataforma de engenharia de IA:
modelos, agentes, tools, evals,
deploy em Azure.*

Engenharia

FORTES

- Multi-modelo, multi-framework
- Foundry Agent Service + SDK
- Evals nativos + tracing
- Integra Azure full-stack

ATENÇÃO

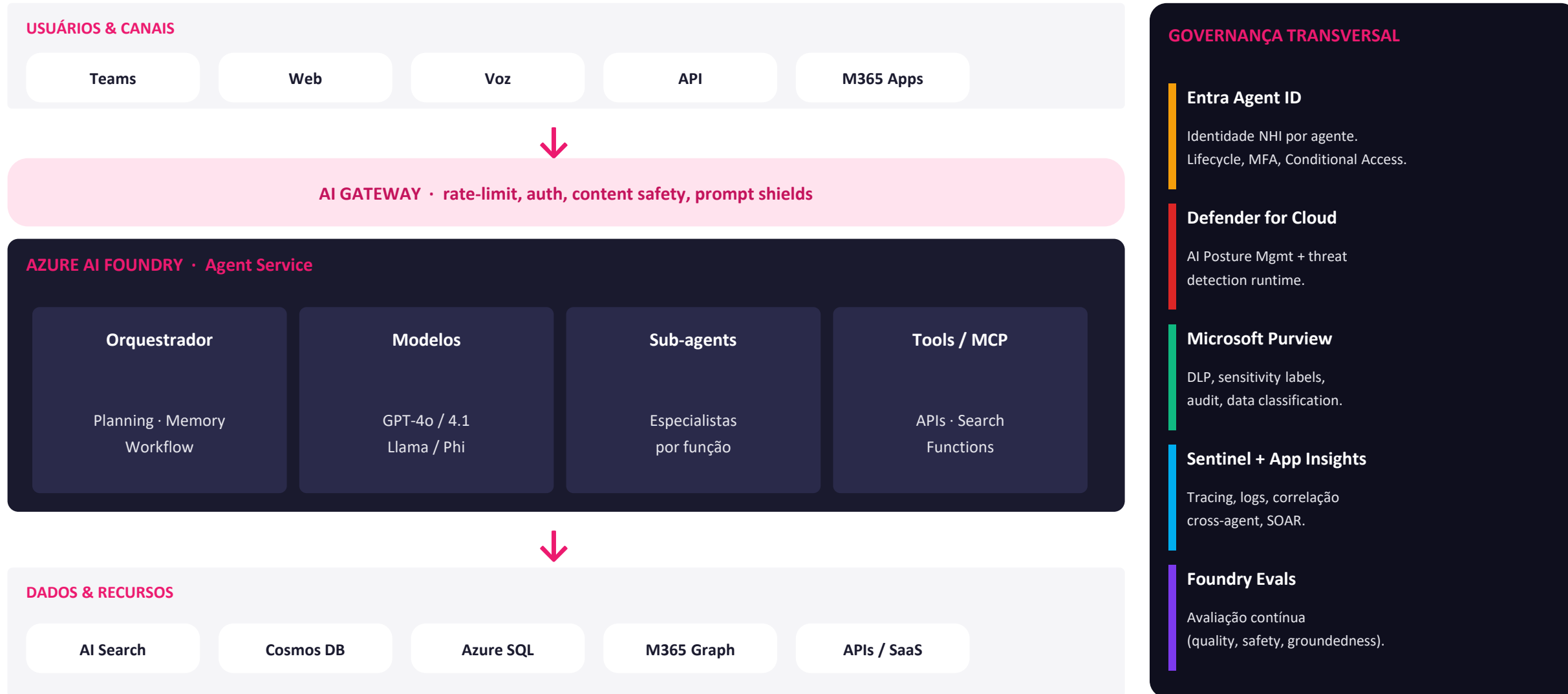
- Curva de aprendizado
- Custo de infra a gerir
- Time precisa maturidade DevOps

Pilares de governança Microsoft para agentes

Como cada pilar de governança da Microsoft endereça os riscos do OWASP Agentic Top 10.

Risco principal	Pilar de governança	Ferramenta Microsoft	O que ativa
ASI01 Goal Hijack ASI06 Memory Poisoning	Security controls (content & input)	Azure AI Content Safety (Prompt Shields, Groundedness)	Filtro de input/output, detecção de indirect prompt injection, validação de fundamentação
ASI02 Tool Misuse ASI05 RCE	Security controls (runtime)	Azure AI Foundry Guardrails + AI Gateway	Política de tools por escopo, gateway de modelos com rate-limit e auth
ASI03 Identity Abuse (NHI)	Identity & access	Microsoft Entra Agent ID + Conditional Access	Identidade própria por agente, least privilege, MFA-equivalent (client cert / managed ID)
ASI04 Supply Chain (MCP, modelos)	Lifecycle management + posture	Defender for Cloud (AI Security Posture Mgmt)	Inventário de modelos/agentes, detecção de shadow AI, CVE em MCP servers
ASI07 Inter-Agent comms ASI08 Cascading	Monitoring & response	Microsoft Sentinel + Defender for Cloud (AI alerts)	Correlação cross-agent, playbooks SOAR de resposta a incidente
ASI09 Human-Agent Trust ASI10 Rogue Agents	Data governance + HITL	Microsoft Purview + Copilot Studio HITL	Sensitivity labels que viajam com o output, DLP, aprovação humana em ações de impacto

Arquitetura de referência: agente em Azure



Aplicação prática: Agente de Vendas no E-Commerce

CENÁRIO

Agente de Vendas autônomo que recebe leads do site, qualifica, agenda demo e envia e-mail de follow-up: usando CRM, calendário e e-mail corporativo.

RISCOS IDENTIFICADOS

Threat modeling baseado em OWASP Agentic Top 10

ASI01

Lead malicioso injeta instrução escondida no formulário para redirecionar e-mails para domínio do atacante

ASI03

Identidade do agente compartilhada com humanos → impossível auditar quem fez o quê

ASI06

Histórico de leads (memória) envenenado por concorrente faz agente desqualificar leads válidos

ASI09

Cliente acredita que está conversando com humano → revela dados sensíveis indevidamente

Privacidade

Dados pessoais de leads (LGPD) chegam ao prompt; provider externo pode logar

MITIGAÇÕES APLICADAS

Stack Microsoft / Azure

Foundry

Content Safety + Prompt Shields no input do formulário; groundedness check antes de enviar e-mail

Entra ID

Identidade dedicada "agent-sdr-prod" com Conditional Access; logs separados de identidades humanas

Purview

Sensitivity labels nos dados do CRM; DLP bloqueia exfiltração de PII para domínios externos

HITL

Aprovação humana obrigatória em e-mails para contas de alta receita (>R\$ 100k de pipeline estimado)

Defender

AI alerts em Sentinel; playbook automático bloqueia o agente se detectar 3 falhas seguidas



Encerramento e Projeto Final

Quantum Commerce



4 ideias para levar para casa

01

Agentes mudam o vetor de risco

Saímos de "resposta errada" para "ação errada". O impacto deixa de ser cognitivo e passa a ser operacional, financeiro e legal.

02

Riscos amplificados + riscos novos

Vieses, alucinações e privacidade continuam. Soma-se: goal hijack, tool misuse, cascading failures, rogue agents, identidade não-humana.

03

Defesa em profundidade é obrigatória

Nenhum controle isolado resolve. Combine: prompt safety + tool gateway + identidade NHI + observabilidade comportamental + HITL.

04

Governança progressiva, não tudo de uma vez

Comece pelas 3-4 práticas críticas (access control, logging, eval, HITL) e evolua conforme a autonomia e o risco aumentam.

Projeto final - Quantum Commerce

BRIEFING

*Quantum Commerce é um varejista omnichannel que pretende implantar agentes de IA em vendas, atendimento e supply chain. Vocês são a banca de Responsible AI: desenvolvam o **PLANO DE GOVERNANÇA DE DADOS E IA** para a empresa, considerando **TODOS** os conteúdos cobertos na disciplina (partes 1 a 5).*

ESCOPO — DEVE COBRIR OS CONTEÚDOS DAS 5 AULAS

Aulas 1-2

Fundamentos

Governança de dados (DAMA), princípios de Responsible AI, riscos da IA tradicional e generativa.

Aula 3

Frameworks & Regulação

ISO/IEC 42001, NIST AI RMF, EU AI Act, LGPD, contexto brasileiro (Marco da IA).

Aulas 4-5

Mitigação & Agentes

Justiça, transparência, privacidade, segurança + riscos específicos de Agentic AI.

ENTREGÁVEIS DO PLANO DE GOVERNANÇA

Inventário e classificação de casos

3–6 casos de uso priorizados (IA tradicional, generativa, agêntica).
Risco e zona de governança.

Governança de dados

Modelo DAMA aplicado: qualidade, classificação, lifecycle, LGPD, linhagem para IA.

Plano de Responsible AI

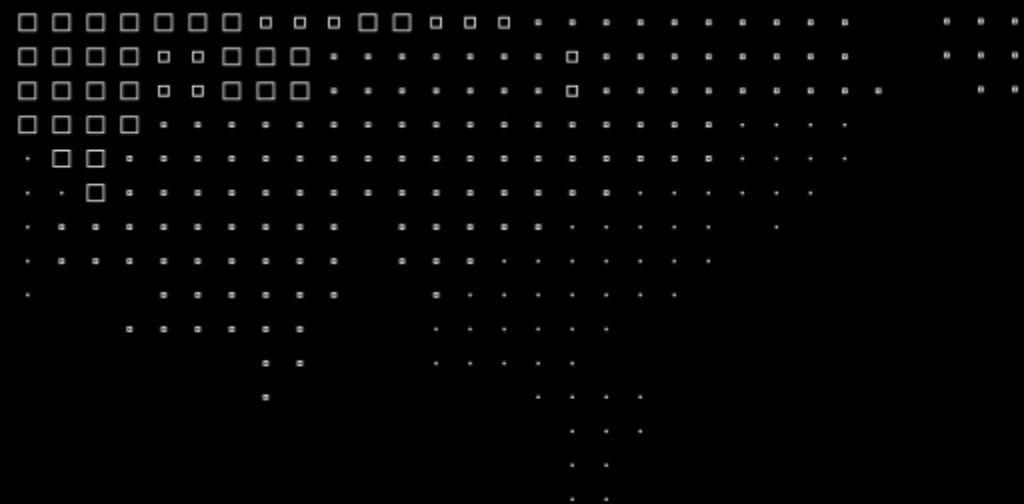
Princípios, controles por risco, ferramentas, papéis, métricas e integração regulatória.

Roadmap e operação

90 / 180 / 365 dias. Quick wins, comitê, processos de decisão e auditoria.

Mais detalhes no Template (documento Word a ser fornecido) · Entrega em grupo

FINAL DA PARTE 5

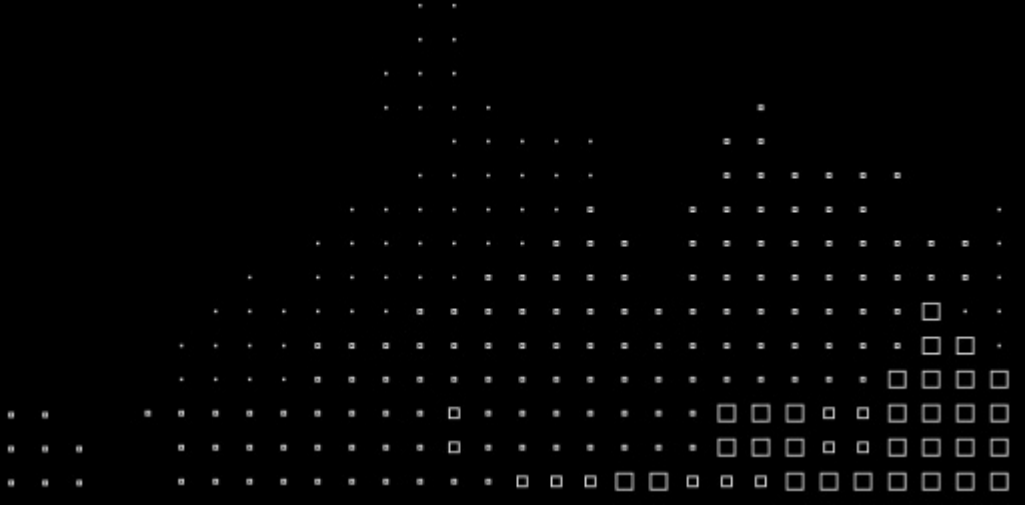


MBA⁺

Copyright © **2026** Professor:

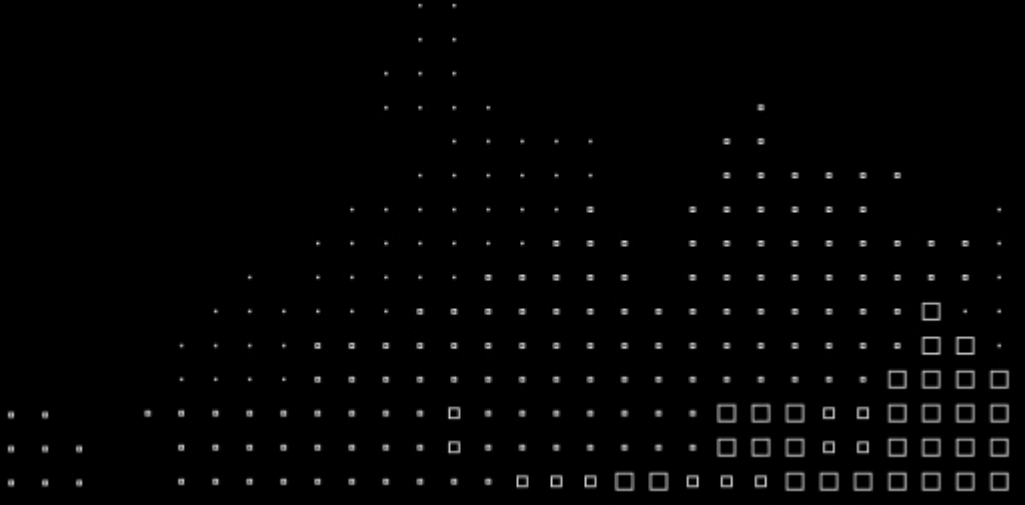
- Sergio Alexandre Naime Mantovani

Todos direitos reservados. Reprodução ou divulgação total ou parcial deste documento é expressamente proibida sem o consentimento formal, por escrito, dos Professores (autores).



MBA⁺

**MBA DATA SCIENCE &
ARTIFICIAL INTELLIGENCE**



OBRIGADO

